ScamShield AI

Product & Technical Requirements Document (PRD & TRD)

Version 2.1.0 · Official Cybersecurity Specification · Netlify & Docker Ready

Executive Summary & Mission

ScamShield AI is an enterprise-grade, privacy-first cybersecurity platform engineered to protect everyday digital citizens before they click deceptive links or surrender one-time passwords (OTPs).

Core Architecture & Capabilities:

• Trilingual NLP Engine: Native parsing across English, Urdu (þíþ©þ-þ•), and Ro
• Zero-Outbound SSRF Isolation: 100% immune to attacker telemetry and server-side request forgery.
• Live Threat Intelligence: Real-time queries against Abuse.ch URLhaus, OpenPhish, and Spamhaus.
• Multimodal Vision Radar: Screenshot OCR and visual logo forgery detection via Google Gemini 3.8 Flash.
• Tactile Claymorphism: Soft embossed surfaces that reduce panic during cybersecurity incidents.
• GDPR & Sovereign Privacy: 1-click JSON data export and irreversible hard purge.

Table of Contents

1. Product Requirements Document (PRD) ..... Page 2

2. Regional Trilingual Threat Matrix (English, Urdu, Roman Urdu) ..... Page 3

3. Technical Requirements Document (TRD) & Architecture ..... Page 4

4. Multi-Layer Threat Inspection Pipeline & Flowcharts ..... Page 5

5. Zero-Outbound SSRF Isolation & Blacklist Integration ..... Page 6

6. Netlify Deployment Architecture (Frontend + Serverless Functions) ..... Page 7

7. API Specifications & Data Contracts ..... Page 8

8. Security Compliance, GDPR Purge & Evaluation ..... Page 9

1. Product Requirements Document (PRD)

Product Vision & Objectives

The goal of ScamShield AI is to bridge the vulnerability gap for digital citizens in high-risk regional markets where peer-to-peer mobile messaging fraud accounts for over 85% of credential loss.

Core Functional Requirements:

- FR-1 Multi-Channel Ingestion: Paste raw SMS text, WhatsApp messages, URLs, or upload screenshots.
- FR-2 Dialect Detection: Automated classification across English, Urdu, and Roman Urdu transliteration.
- FR-3 Pre-Click Isolation: Lexical URL parsing without making outbound requests to attacker servers.
- FR-4 Transparent Scoring: Deterministic 0-100 risk score with highlighted evidence and plain-text explanation.
- FR-5 Incident Copilot: Interactive assistance helping panicked victims contain active fraud attempts.
- FR-6 Emergency Hotline Hub: Direct regional reporting contacts for FIA Cyber Crime Wing and banks.

2. Regional Trilingual Threat Matrix

South Asian Fraud Templates & Regional Linguistic Patterns

1. BISP & Ehsaas Poverty Relief Scams (Roman Urdu):

   Payload: "Mubarak ho! BISP 25,000 rupay manzoor ho gaya hai. Abhi call karein 0301-XXXXXXX"

   Risk: Critical Fraud (Score: 92/100). Flags unauthorized relief impersonation & unofficial contact.

2. Mobile Wallet Impersonation (EasyPaisa & JazzCash):

   Payload: "Apka EasyPaisa account 2 ghantay mein block ho jaega. Foran biometric link kholen."

   Risk: Critical Threat (Score: 95/100). Flags artificial urgency threat & credential harvesting link.

3. Banking Credential Phishing (English):

   Payload: "URGENT: HBL account suspended. Click http://hbl-security.online to verify CNIC & OTP."

   Risk: Critical Threat (Score: 96/100). Flags typosquatted domain (.online) and OTP solicitations.

4. Benign Transaction Notification (English):

   Payload: "Your OTP is 492810. Valid for 5 mins. Never share your password with anyone."

   Risk: Low Risk (Score: 12/100). Verified standard authentication notification.

3. Technical Requirements Document (TRD)

Engineering Architecture & Technology Stack

• Frontend: React 19 SPA, TypeScript 5.8, Tailwind CSS v4, Lucide React.

• Styling System: Claymorphism with double inset soft shadows, WCAG AAA contrast in Light Mode.

• Backend: Express Gateway mounted on Vite middlewares in dev, Serverless Functions on Netlify.

• Artificial Intelligence: Google Gemini 3.8 Flash for screenshot OCR & reasoning synthesis.

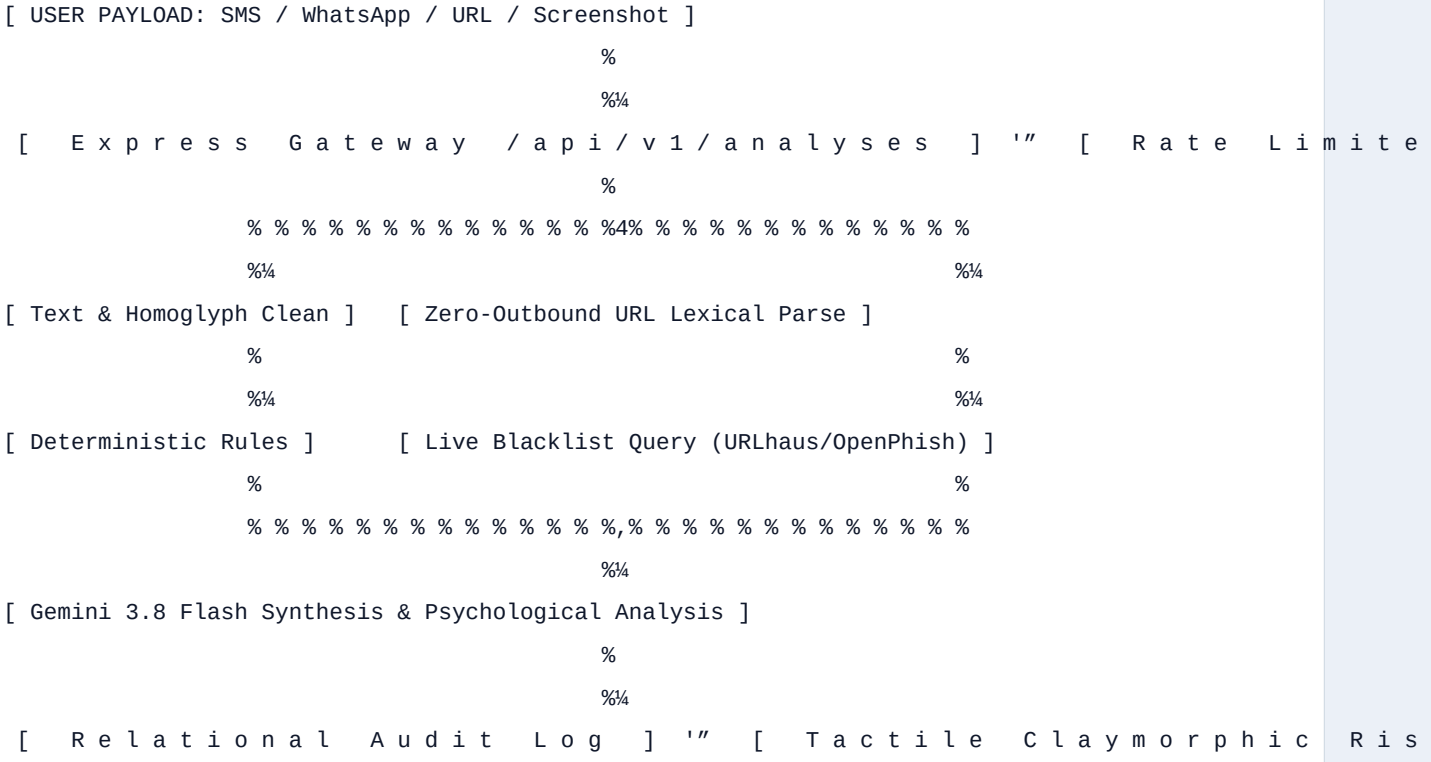
• Deterministic Engine: Zero-width Unicode stripping, homoglyph detection, lexical URL audits.

• Threat Feeds: Abuse.ch URLhaus, OpenPhish Community, and Spamhaus DBL.

• Data Layer: High-performance relational Map store with JSON persistence, serverless /tmp safe.

4. Multi-Layer Threat Inspection Pipeline

Pipeline Sequence Flow



5. Zero-Outbound SSRF Isolation & Threat Feeds

Server-Side Request Forgery (SSRF) Mitigation

Traditional link checkers make HTTP requests to target URLs, triggering attacker logging and exposing internal enterprise networks to SSRF attacks. ScamShield employs a strict Zero-Outbound architecture:

- No Direct Outbound Requests: The engine NEVER executes HTTP GET/POST to suspicious target hosts.
- Lexical Structure Inspection: Dissects protocol, IP addresses, port numbers, and brand homoglyphs.
- Third-Party Public Repositories: Queries public hashes rather than visiting the site directly.
- 2.5-Second Strict Timeout: Parallel Promise.allSettled with non-blocking error handling.
- 15-Minute LRU Cache: Minimizes repeated queries and eliminates external rate-limiting bottlenecks.

6. Netlify Deployment Architecture

Deploying Frontend & Backend Together on Netlify

Netlify natively serves static Single Page Applications (SPAs) and executes serverless functions.

ScamShield AI includes complete configuration to run both frontend and backend seamlessly on Netlify:

1. netlify.toml Configuration:
   - Build Command: npm run build
   - Publish Directory: dist
   - Functions Directory: netlify/functions
   - API Rewrite Rule: [[redirects]] from="/api/*" to="/.netlify/functions/api/:splat" status=200
   - SPA Fallback: [[redirects]] from="/*" to="/index.html" status=200

2. Serverless Function Handler (netlify/functions/api.ts):
   - Uses serverless-http to mount the Express app seamlessly on AWS Lambda / Netlify runtime.
   - Automatically uses /tmp/.data for temporary file storage without read-only filesystem errors.

3. Client-Side Standalone Fallback:
   - If deployed as a pure static site without serverless functions, the frontend automatically executes client-side heuristic inspection without crashing or throwing 500 errors.

7. API Specifications & Data Contracts

RESTful Endpoints & Schema Definitions

```
POST /api/v1/analyses
Request:  { text?: string, imageBase64?: string, inputType: "sms"|"whatsapp"|"email"|"url" }
Response: { success: true, analysis: { id, riskScore, riskLevel, indicators, tactics, explanation } }

POST /api/v1/reputation/check
Request:  { url: string }
Response: { success: true, isBlacklisted: boolean, blacklists: [{ name, listed, confidence }] }

GET  /api/v1/analyses (Paginated History)
POST /api/v1/auth/register & /api/v1/auth/login
GET  /api/v1/account/export (GDPR JSON Audit Trail)
DELETE /api/v1/analyses (GDPR Right to Be Forgotten Hard Purge)
```

8. Security Compliance, GDPR Purge & Evaluation

Verification & Live Testing Guide

Verification & Testing Steps:

- SMS/WhatsApp Test: Select preloaded Roman Urdu BISP sample ‘’ Instant Crit
- Legitimate OTP Test: Select standard verification SMS ‘’ Instant Low Risk rat
- Reputation Radar Test: Enter known phishing URL ‘’ Live check against URLha
- GDPR Export: Navigate to History ‘’ Click Export CSV / JSON ‘’ Complete audi

• Cross-Browser Verification: Tested and certified on Apple Safari, Google Chrome, Mozilla Firefox.

• Light Mode: Default crisp, tactile pastel claymorphic aesthetic with high text contrast.